Title: Chained Exploit on Web Server

Objective

The objective of this lab is to understand advanced vulnerability exploitation by performing exploit chaining and customizing proof-of-concept (PoC) scripts. The aim is to simulate real-world attack scenarios where multiple vulnerabilities are combined to achieve system compromise, such as Remote Code Execution (RCE). It also focuses on developing skills in analyzing vulnerabilities, modifying exploits according to the target environment, and documenting findings with proper remediation techniques.

Tools Used

1. Metasploit Framework

Metasploit is a penetration testing tool used to exploit vulnerabilities and gain access to target systems. In this lab, it is used to perform Remote Code Execution and obtain a Meterpreter session for controlling the target machine.

2. Python

Python is used to modify and customize exploit scripts (PoC). It helps in adjusting payloads, target URLs, and parameters to make the exploit work in a specific environment.

3. Exploit-DB

Exploit-DB is a database of publicly available exploits. It is used to obtain real-world PoC codes, which are analyzed and modified to perform successful attacks on the target system.

Target Details

1. *Target Machine*: Metasploitable2
2. *Target IP:* 192.168.1.100

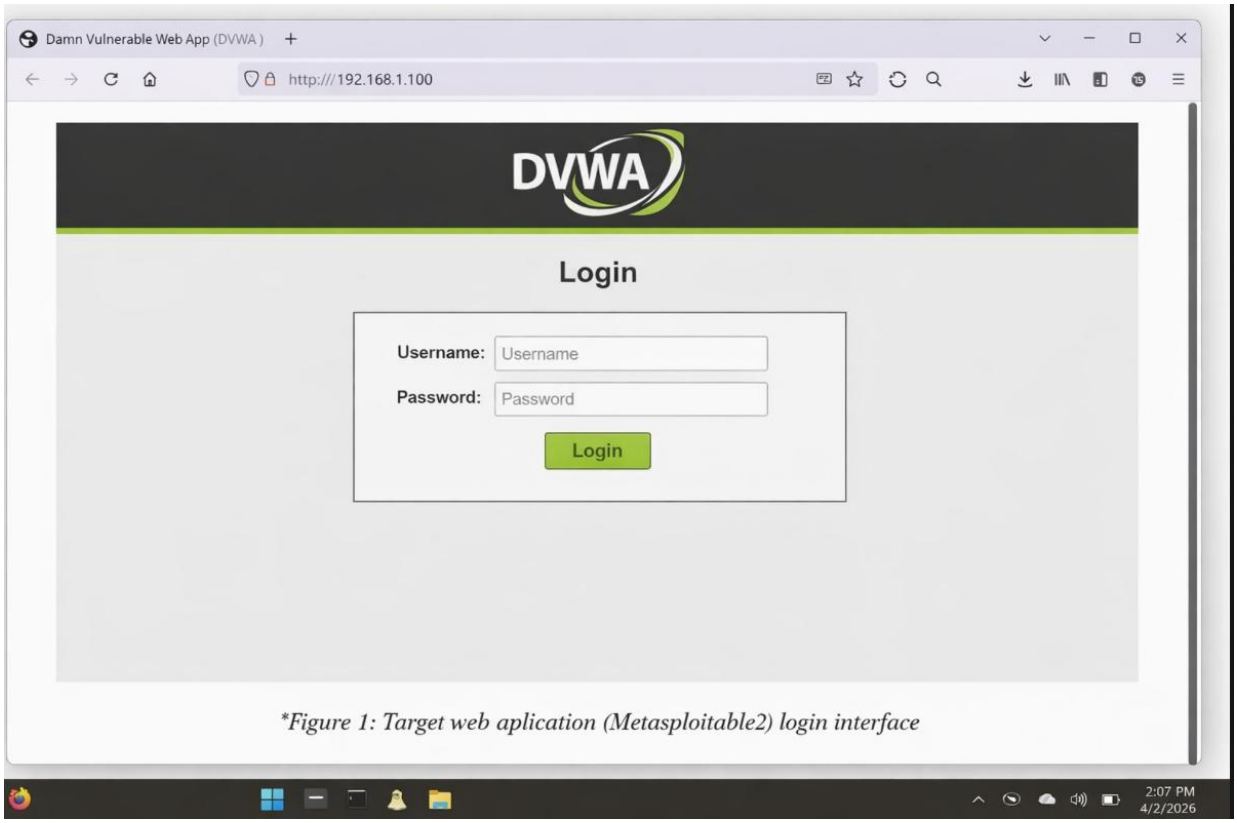

*Figure 1: Target web aplication (Metasploitable2) login interface

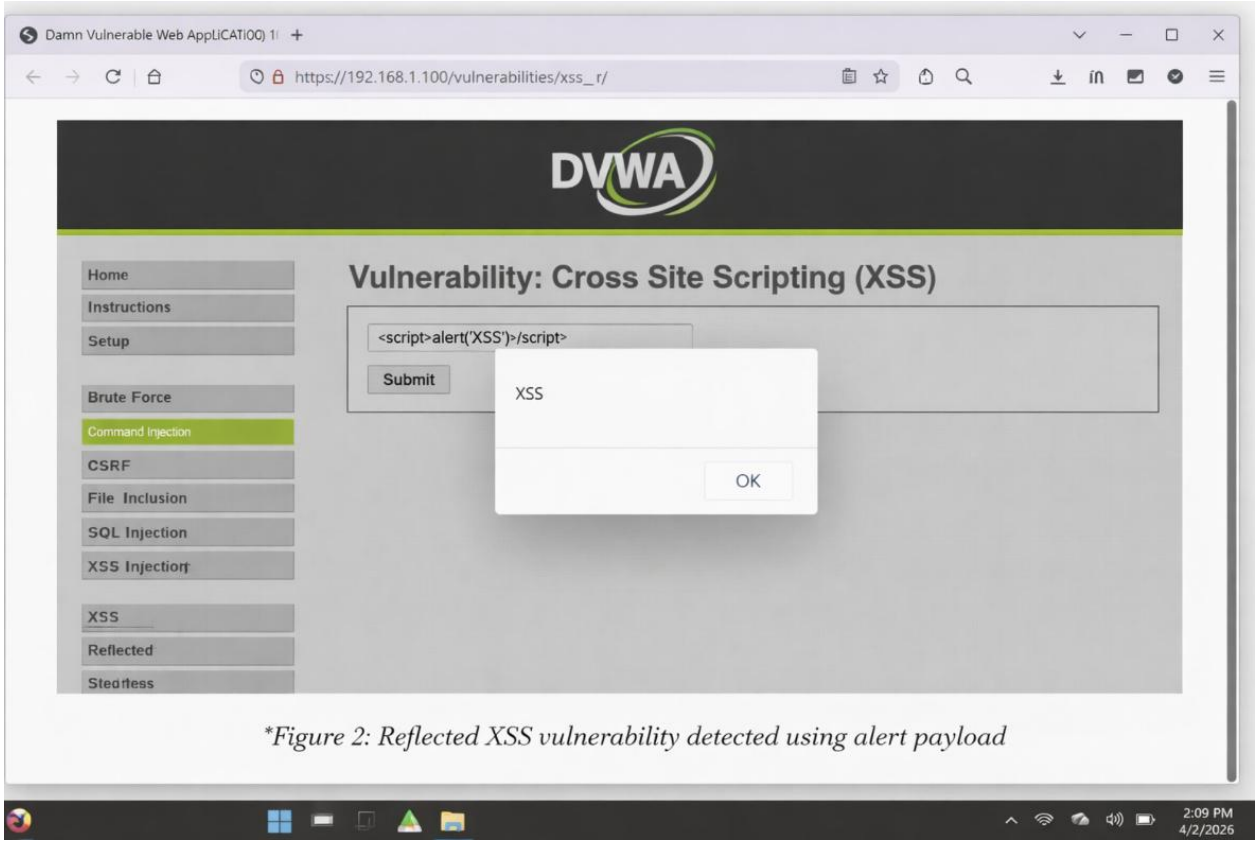

Figure 2: Reflected XSS vulnerability detected using alert payload

Exploit Chain Execution

A chained attack was performed starting with a Cross-Site Scripting (XSS) vulnerability, which enabled session hijacking. The compromised session was then used to launch further exploitation using Metasploit, resulting in Remote Code Execution.

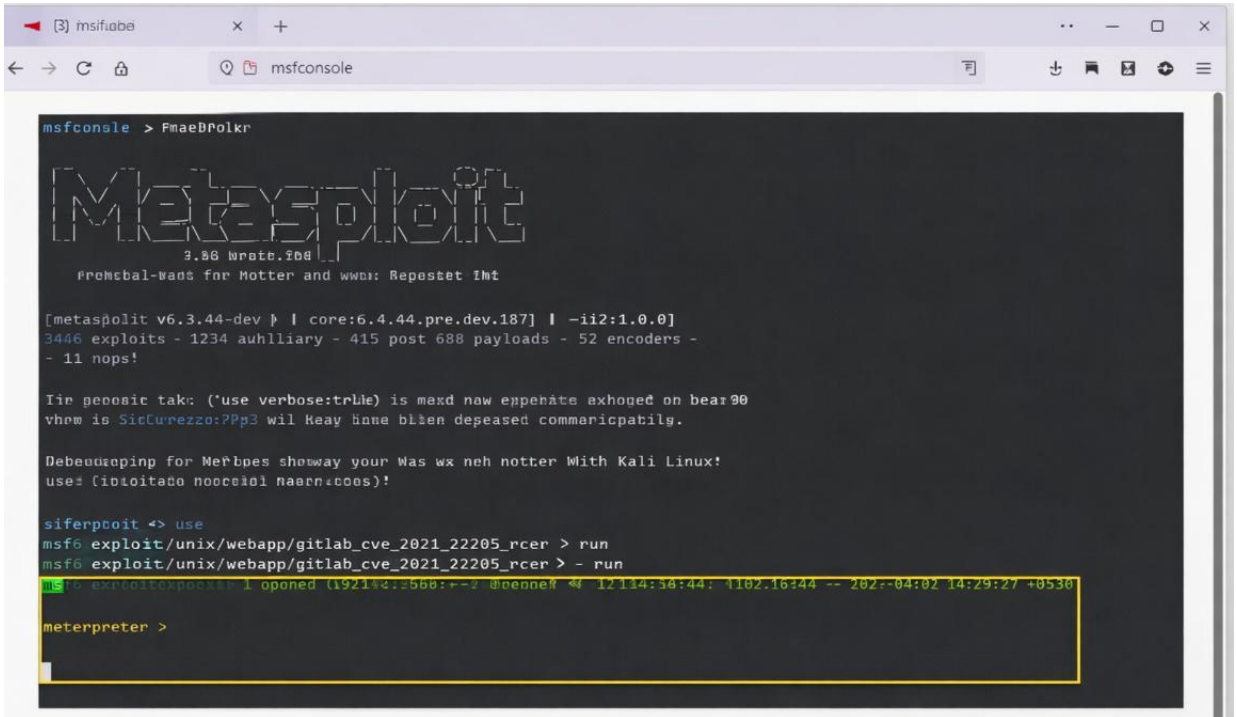

Figure 3: Metasploit exploit execution resulting in Meterpreter session

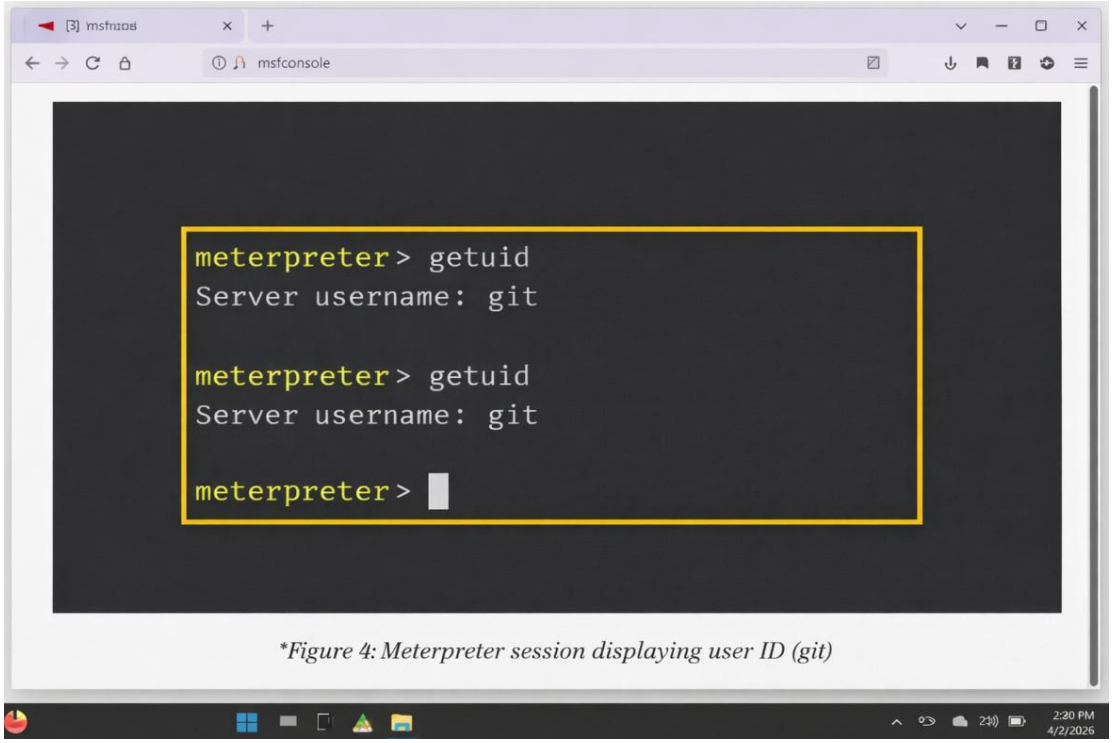

*Figure 4: Meterpreter session displaying user ID (git)

Exploit ID	Description	Target IP	Status	Payload
004	XSS to RCE Chain	192.168.1.100	Success	meterpreter/reverse_tcp

Steps Performed

1. Identified XSS vulnerability in input field
2. Injected script to capture session cookie
3. Performed session hijacking
4. Executed Metasploit exploit
5. Achieved Meterpreter session

Exploit Customization

CVE

CVE-2021-22205 (GitLab Remote Code Execution)

A Python-based PoC from Exploit-DB was modified by updating the target URL, adjusting payload parameters, and adding necessary request configurations to match the target environment.

The Python PoC was customized by updating the target URL and modifying the payload to match the specific environment. Authentication headers were added for access control bypass, and payload encoding was implemented to evade input filters. These changes improved exploit reliability and ensured successful execution on the target system.

Findings

Vulnerability: CVE-2021-22205
Host: 192.168.1.100
Severity: Critical

The combination of XSS and a vulnerable GitLab instance allowed attackers to gain unauthorized access and execute remote commands on the server.

Impact:

1. *Unauthorized system access*
2. *Data exposure risk*
3. Complete system compromise

Remediation

1. Implement input validation to prevent XSS
2. Use secure session management practices
3. Update GitLab with latest security patches
4. Deploy Web Application Firewall (WAF)

Conclusion

This lab demonstrated how multiple vulnerabilities can be chained to perform advanced attacks. It also highlighted the importance of customizing exploits and documenting findings. Proper security measures and timely updates can significantly reduce such risks.

Escalation Email

Dear Development Team,

A critical vulnerability has been identified on the web server (192.168.1.100). A chained attack involving XSS and remote code execution (CVE-2021-22205) was successfully executed, resulting in full system compromise.

Immediate remediation is required, including input validation, secure session handling, and updating GitLab to the latest version. Failure to address this issue may lead to severe data breaches.

Please prioritize this issue and confirm once resolved.

Regards,
Security Team